

Domain Week 04: 2. API Security Testing Lab

Name: Ryan Lobo

Submission Date: 8/4/26

API Security Testing Lab

Tools: Burp Suite, Postman, sqlmap, Apache, MySQL, Python 3, DVWA API.

Target: DVWA API lab with REST and GraphQL endpoints, tested in an isolated environment.

Executive Summary

The lab focused on API enumeration, authorization testing, and GraphQL fuzzing using Burp Suite and Postman.

The audio notes indicate manual interception of requests, token manipulation in Repeater, and testing whether changing IDs or authorization values could expose unauthorized data access.

Test Setup

The setup included installing Postman, DVWA, Apache, and MySQL, then creating API files inside the DVWA directory, including a user API and a GraphQL endpoint.

A browser proxy was configured through Burp Suite so requests could be intercepted and modified before being forwarded to the application.

The workflow also included a database-backed API response path, which is useful for testing injection, access control, and token validation behavior.

Test Log

Test ID	Vulnerability	Severity	Target Endpoint
008	BOLA	Critical	/api/users
009	GraphQL Injection	High	/graphql

The audio notes specifically describe changing an ID from 1 to 2 in Burp Repeater to test unauthorized access, which matches a BOLA-style control test.

They also mention GraphQL work, including a separate GraphQL file and adding data for testing, which supports the GraphQL injection test entry.

Manual Testing

Burp Suite was used as the main interception point, with requests sent to Repeater for parameter tampering and authorization checks.

A token-manipulation attempt was performed, and the notes suggest a false or invalid token condition was observed during authorization testing.

This kind of workflow is useful for checking whether the API improperly trusts client-controlled identifiers or weak token validation logic.

Checklist

- Enumerate API endpoints.



- Test for BOLA using Burp Suite.
- Fuzz GraphQL queries in Postman.
- Validate token handling and authorization logic.
- Record any unexpected data exposure or access escalation.

Summary

The API lab used Burp Suite and Postman to inspect DVWA endpoints, intercept requests, and test authorization weaknesses such as BOLA and GraphQL injection.

Manual request editing in Repeater and token manipulation were central to the assessment, and the exercise demonstrated how API access control flaws can expose unauthorized resources.

50-word summary:

The API security lab used Burp Suite, Postman, and sqlmap to test a DVWA API for authorization flaws and injection issues. Requests were intercepted, IDs were modified in Repeater, and token behavior was checked. GraphQL queries were fuzzed to identify weak access control and input-validation weaknesses in the lab.